

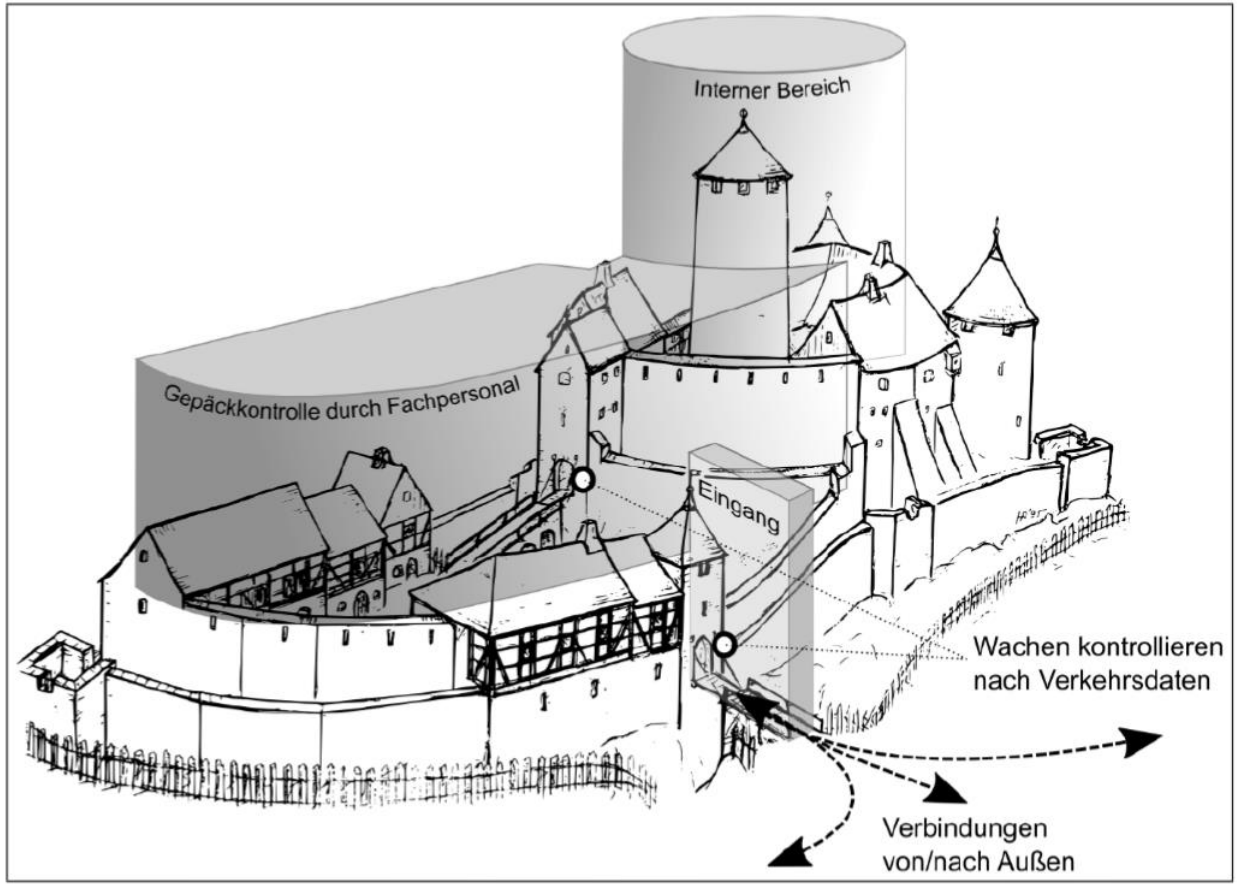
IT Security Basics

Firewalls and Perimeter Security

Firewalls

FH University of Applied Sciences TECHNIKUM WIEN

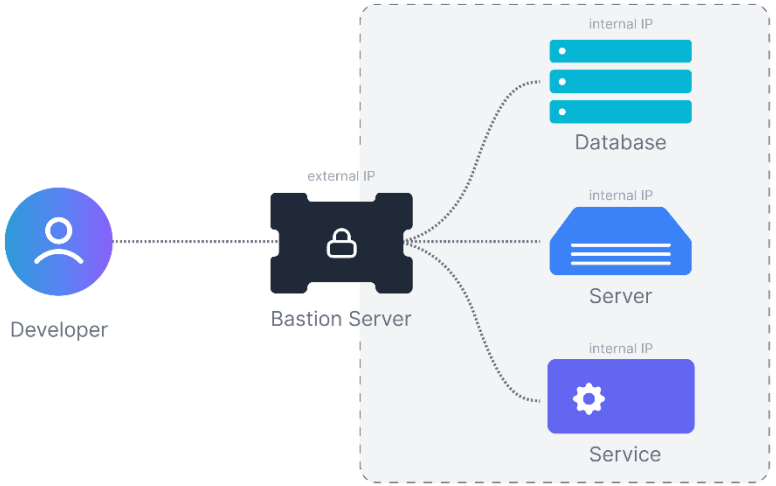
Firewall??



Source: https://de.m.wikipedia.org/wiki/Datei:Schloss_Voigtsberg_im_17._Jh..jpg

Bastion Host

- Bastion ⇒ facility projecting from the line of a rampart
- Connects private network to a public (insecure) network
- Also referred to as Jump Host
- Bastion Host runs a specially secured OS (system hardening)
  - Reduced permissions for executing processes
  - Minimalistic setup, no dev-libs
- Operation ideally in file system read-only mode



Source: https://adaptive.live/blog/how-to-set-up-an-aws-bastion-host-or-a-jump-server

Firewall architecture

- Host-Based
  - Dedicated filter implemented as a software module on the host
- Personal Firewall (host based)
  - Protect access from outside
  - Monitor outgoing traffic
  - Tight protection of the system
  - Detection of malware infections
  - Can make application-dependent access decisions
    - Traffic control via OS process
    - Integrated packet filter

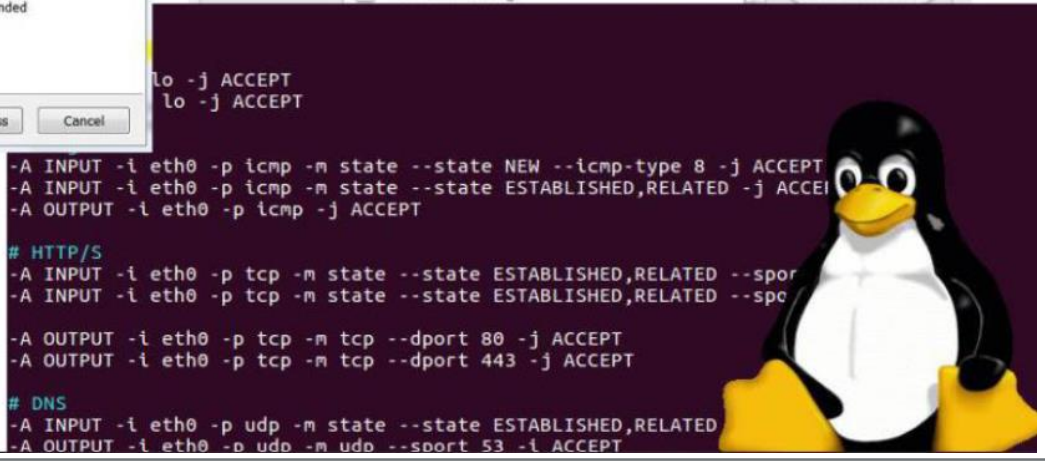


Source: https://personalfirewall.comodo.com/firewall-for-windows-10.php

Firewall architecture



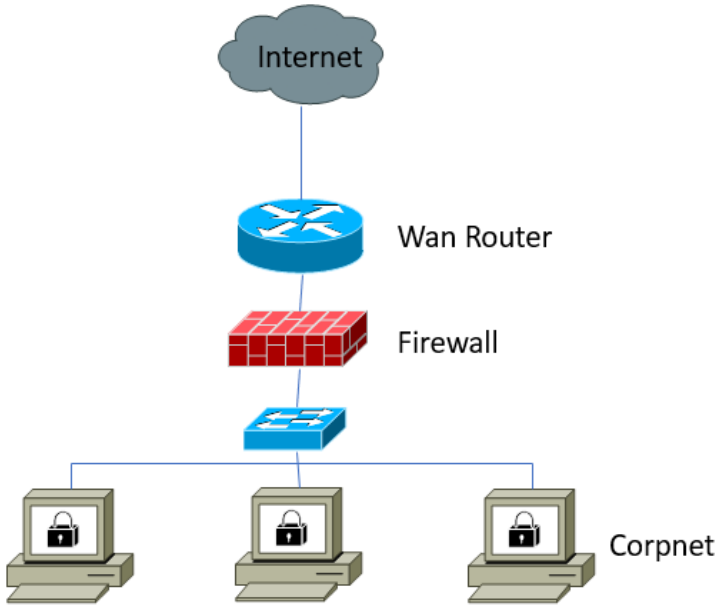




Firewall architecture

Single-box architecture

- Uses exactly one firewall to protect the whole network
- Filtering activity concentrated in one instance / system
- Advantages:
  - Simple implementation and configuration
  - Cheap
- Disadvantages:
  - Unsuitable for complex network structures
  - Single point of failure



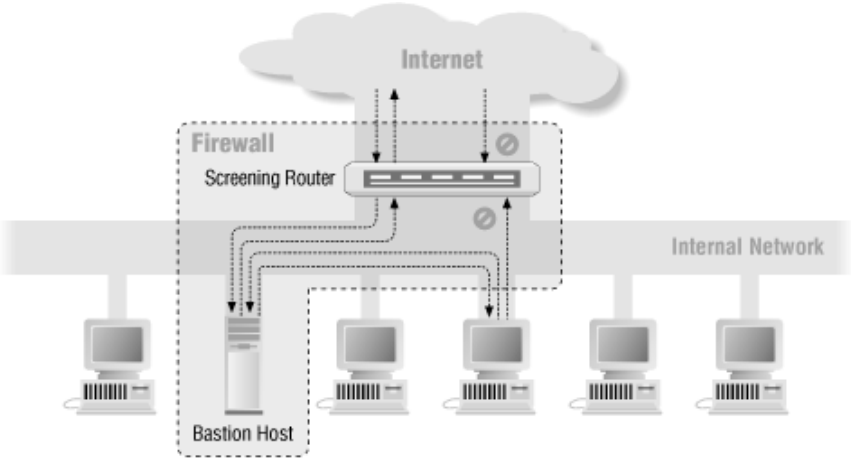
Single Firewall Architecture

Source: https://www.oreilly.com/library/view/practical-network-scanning/9781788839235/3805fdbe-01bd-4cea-8ca1-e7bff1fc5ebf.xhtml

Firewall architecture

Screened host architecture

- Screened Host or Single Homed Bastion Host
- Combines a firewall and bastion host so secure the network
  - Only bastion hosts communicates internal
- Advantages:
  - Additional security due to bastion host
  - Separated application filter and packet filter
- Disadvantages:
  - Firewall and bastion hosts are single point of failure → requires extreme good hardening



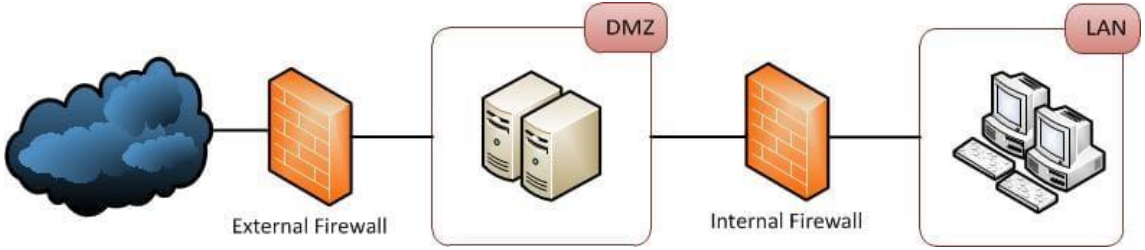
Source: https://docstore.mik.ua/orelly/networking_2ndEd/fire/ch06_02.htm#google_vignette

Firewall architecture

Screened subnet architecture

Double Bastion Inline Firewall

- Additional network segment isolates the internal network from the public network
- DMZ network - Demilitarized Zone
  - Controlled access from/to the external network
  - Web server, file server, name server, mail server,...
  - Network specific information about the internal network hidden
- Extremely secure

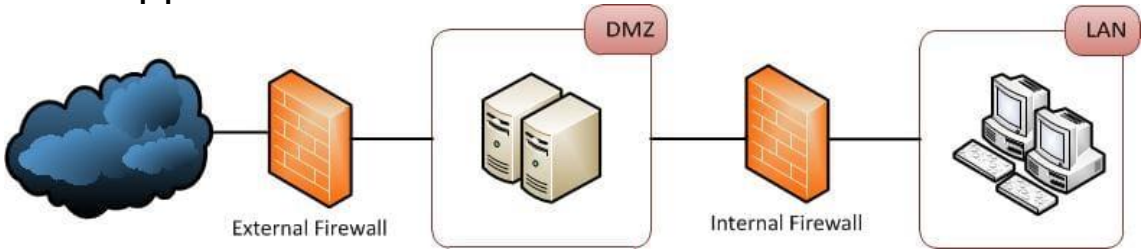


Source: https://www.between-two-firewalls.com/why-between-two-firewalls/

Firewall architecture

Screened subnet architecture
Double Bastion Inline Firewall

- Outer Screening Router
  - Protects network and DMZ from attacks
  - Prevents unauthorized access to the Internet from the inside
- Inner Screening Router
  - Controls access to the internal network
  - Only accepts connections from the application filter
- Disadvantages
  - Higher effort to configure
  - More expensive



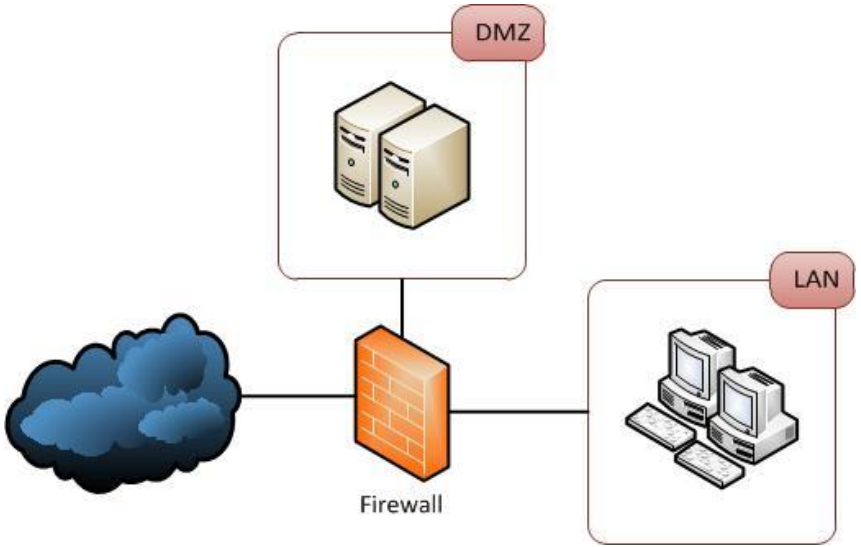
Source: https://www.between-two-firewalls.com/why-between-two-firewalls/

Firewall architecture

Screened subnet architecture

Single Bastion Inline Firewall

- The principle is identical to Double Bastion Inline Firewall but only uses one firewall
- One Bastion Host / Firewall with 3 network interfaces
  - Internal and external screening router at the same time
- DMZ is connected via "T-piece"
- Cheaper but less secure than with 2 firewalls

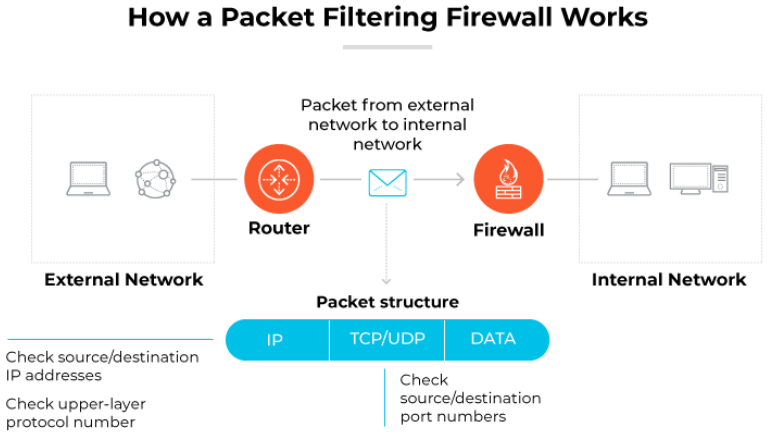


Source: https://security.stackexchange.com/questions/13556/public-dmz-network-architecture

Types of firewalls

Packet filter

- Rules to ensure access control for incoming and outgoing data packets
- Logs access violations and alert
- The decision is based on the respective traffic data (header)
  - Link layer: e.g. MAC address - OSI Layer 2
  - Network layer: e.g. IP addresses – OSI Layer 3
  - Transport layer: e.g. TCP / UDP ports – OSI Layer 4

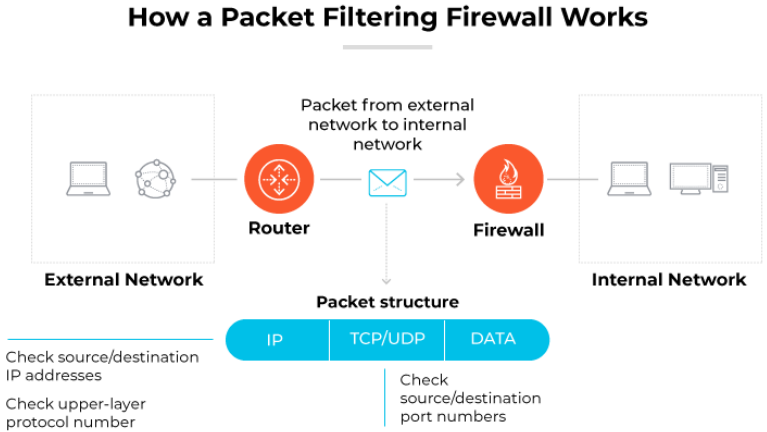


Source: https://www.paloaltonetworks.com/cyberpedia/what-is-a-packet-filtering-firewall

Types of firewalls

Packet filter

- Advantages
  - Easy to implement
  - Application independent
  - Performant
- Disadvantages:
  - Filter decision only based on traffic data
  - No application-specific differentiations
  - Cannot check connections only looks at singe packages



Source: https://www.paloaltonetworks.com/cyberpedia/what-is-a-packet-filtering-firewall

Types of firewalls

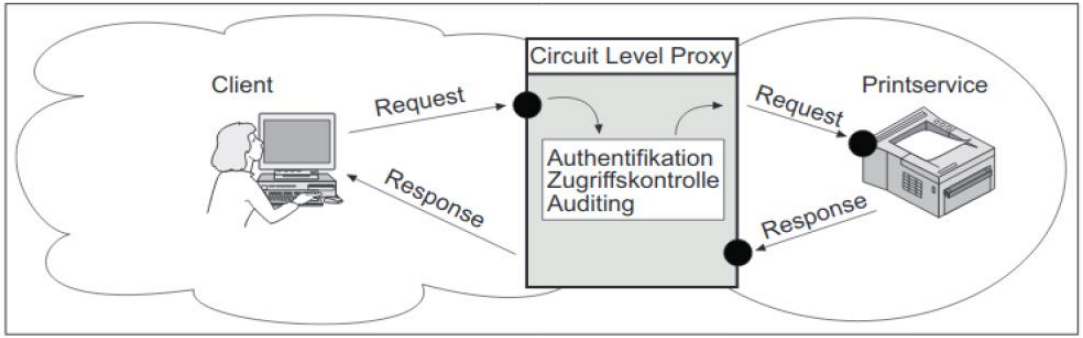
Stateful Inspection firewall

- Basically works like a packet filter firewall
- Difference:
  - Stores open connections into a state table
  - Only allows incoming packages that belongs to an existing connection
- Advantage:
  - Protects against spoofing and replay attacks
- Disadvantages:
  - Higher performance needed
  - Vulnerable to DDoS attacks when opening too much connections

Types of firewalls

Circuit Level Proxy

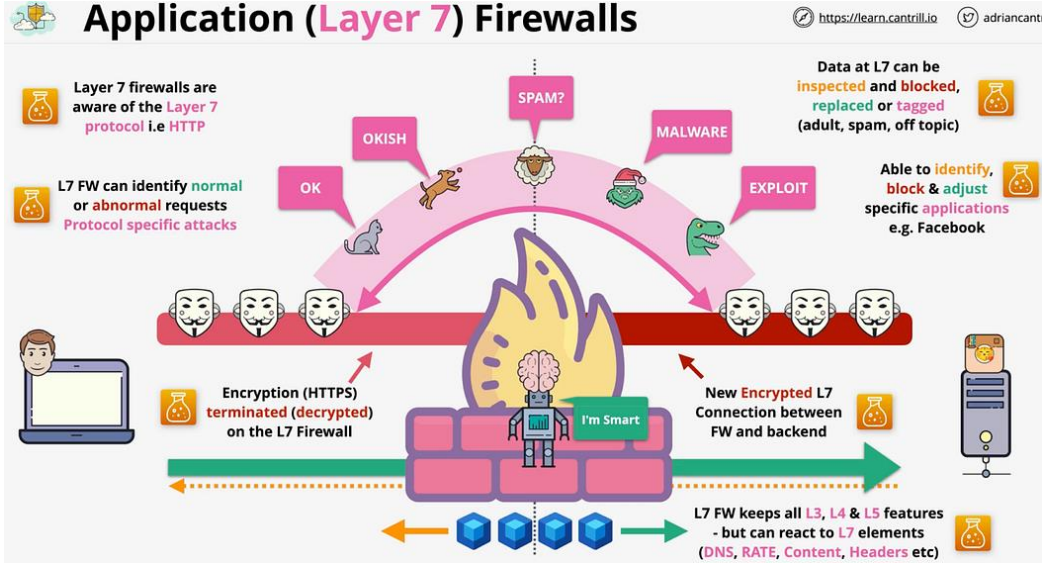
- Proxy between client and server - session layer (e.g.: SOCKS)
- Has no knowledge about the application protocol
- Proxy executes requests independently (=deputy)
- Can perform authentication
- Internal network remains hidden



Types of firewalls

Application Layer Firewall

- Understand the application protocol → works on layer 7
- Access control and accounting can be user-specific
- Can also check content of the packages (= deep packet inspection)
- Log-files offer conclusions on application data
- Dedicated application level proxies per service / application

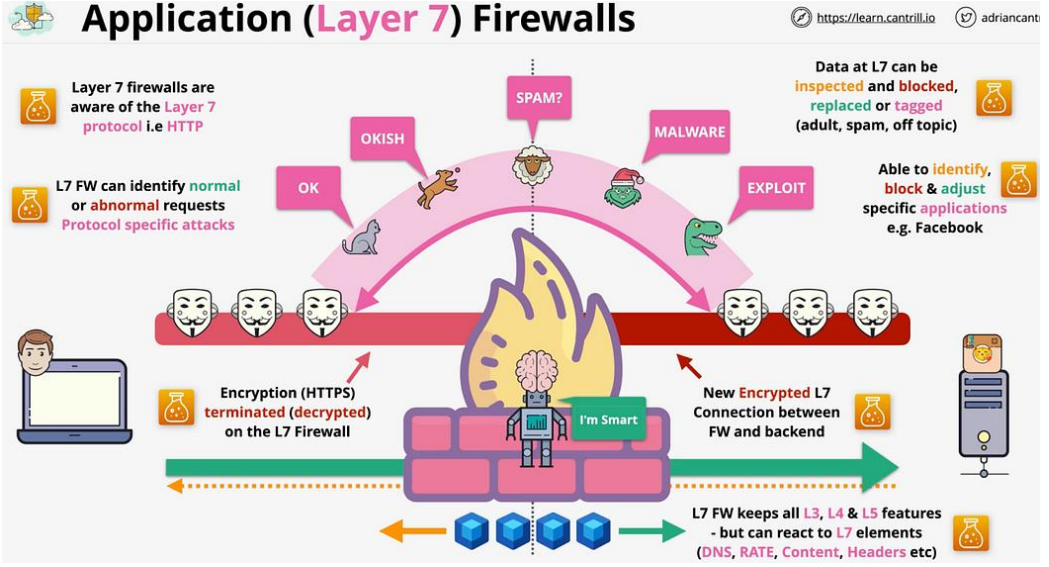


Source: https://walid-mahmoud.medium.com/application-layer-7-firewalls-cb3b803d7efb

Types of firewalls

Application Layer Firewall

- Advantages
  - Extremely high level of security
- Disadvantages
  - Reduced performance and speed degradation
  - Expensive



Source: https://walid-mahmoud.medium.com/application-layer-7-firewalls-cb3b803d7efb

Types of firewalls

Next Generation Firewall

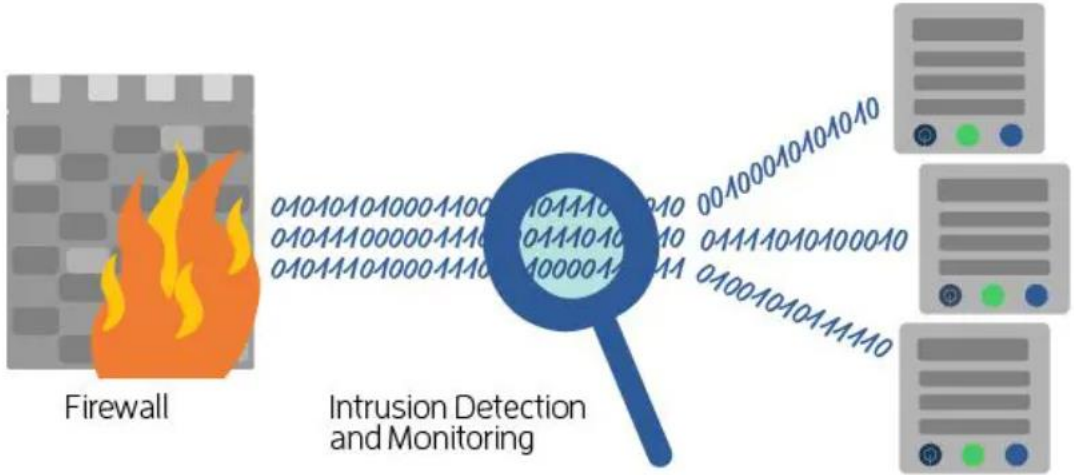
- Classical Firewall including additional features
  - Standard firewall function: Filtering packages
  - Integrated Intrusion Detection / Prevention Systems
  - Application awareness: Detection and blocking of (risky) apps
  - Deep packet inspection
  - Malware detection possible
  - Threat intelligence → detection of zero-day exploits possible
  - VPN awareness → detect VPN
  - Allows policies on user level instead of just IP addresses
- Disadvantage: Needs higher performance

Intrusion Detection Systems

FH University of Applied Sciences TECHNIKUM WIEN

Intrusion Detection System

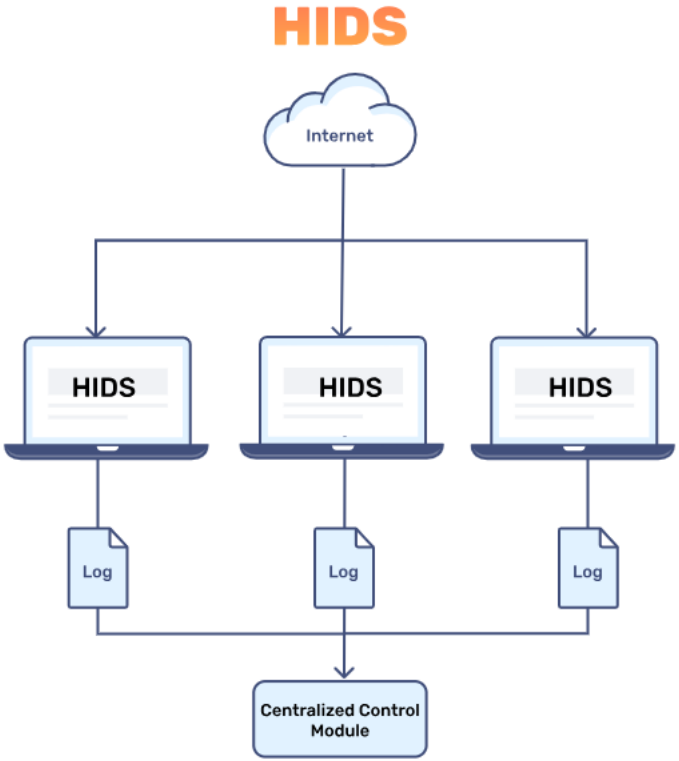
- In short: IDS
- Real time monitoring of network traffic
- Detects and reports suspicious network traffic
  - System / Network administrator the takes care of the issue
- Can be divided into two main types:
  - Host based IDS
  - Network based IDS



Source: https://cyberhoot.com/cybrary/intrusion-detection/

Intrusion Detection System - Types

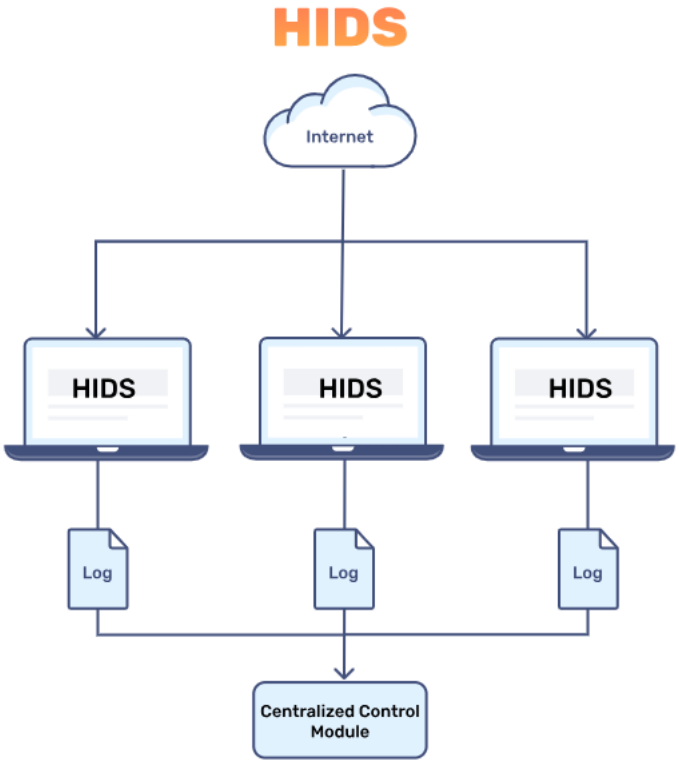
- Host based IDS (HIDS)
  - Directly on a host to be monitored
  - Monitors activity of users and programs
  - Monitors changes in files or configurations
  - Processes within the operating system as a basis for measurement
  - Precise resolution down to user level
  - Mostly closely interlocked with Personal-/Host-Based Firewall



Source: https://bunny.net/academy/security/what-is-network-intrusion-detection-nids/

Intrusion Detection System - Types

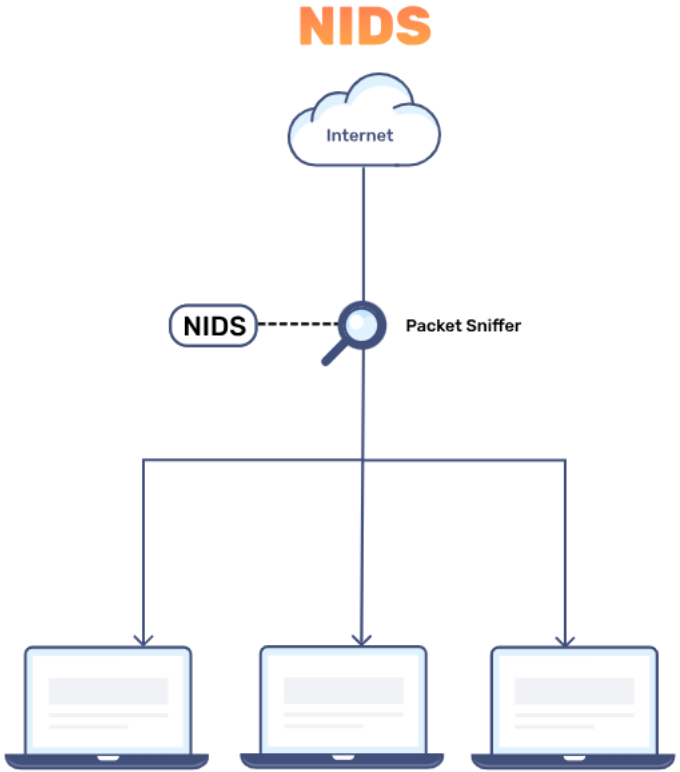
- Host based IDS (HIDS)
  - Advantages
    - Fewer false positives
    - Closer to the operating system
    - Can view traffic decrypted
    - Attacks on the system are detected
  - Disadvantages
    - High consumption of system resources
    - Scalability - costly for any host on the network
    - Local incident logging



Source: https://bunny.net/academy/security/what-is-network-intrusion-detection-nids/

Intrusion Detection System - Types

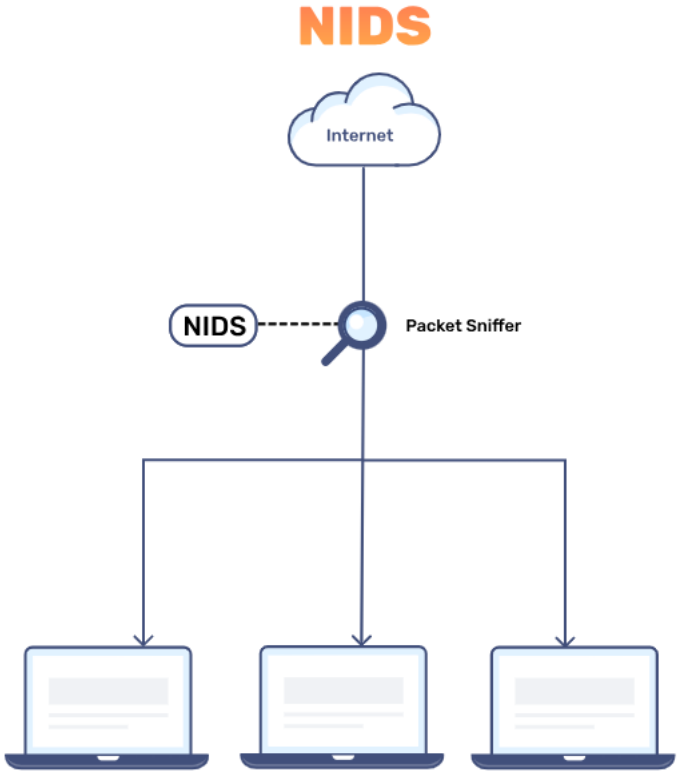
- Network based IDS (NIDS)
  - Monitors the data traffic of computer systems from a position in the network
  - Analysis concerns traffic flow, as well as user data of the packets
  - Inline sensor
    - Channelized data stream, real-time traffic analysis
  - Passive sensor
    - Connected as a "T-piece" to the "data highway"
    - Copies of all data traffic is monitored
    - Does not cause any delay in the network



Source: https://bunny.net/academy/security/what-is-network-intrusion-detection-nids/

Intrusion Detection System - Types

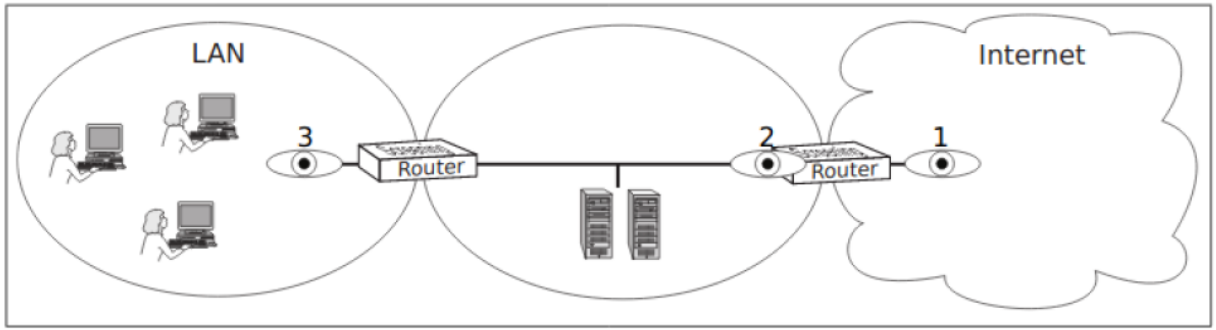
- Network based IDS (NIDS)
  - Advantages
    - Attacks are detected before the hosts
    - Reduced costs (compared to host-based)
    - Better scalability
    - OS independent
    - Cross platform protection
  - Disadvantages
    - Reduction of the NW bandwidth with inline sensor (=bottle neck)
    - Encrypted traffic cannot be viewed
    - Traffic that bypasses the segment is not detected



Source: https://bunny.net/academy/security/what-is-network-intrusion-detection-nids/

Intrusion Detection System - Types

- Network based IDS (NIDS)
  - Placement of the sensors
    - 1 - All traffic is recorded, performance intensive
    - 2 - Usual NIDS positioning at the outer screening router, records only traffic permitted from the firewall
    - 3 - Detects direct attacks on hosts / malware on the LAN



- Hybrid IDS
  - Combination of HIDS and NIDS

Intrusion Detection System – Detection Methods

- Signature-based methods
  - Uses a database that stores known signatures of an attack
  - Such signatures could be
    - IP addresses
    - Filenames
    - Hash values of files
    - Domains
    - Etc.
  - Advantages
    - Low False Positive rates
  - Disadvantages
    - Can only detect known attacks and no Zero-Day exploits

Intrusion Detection System – Detection Methods

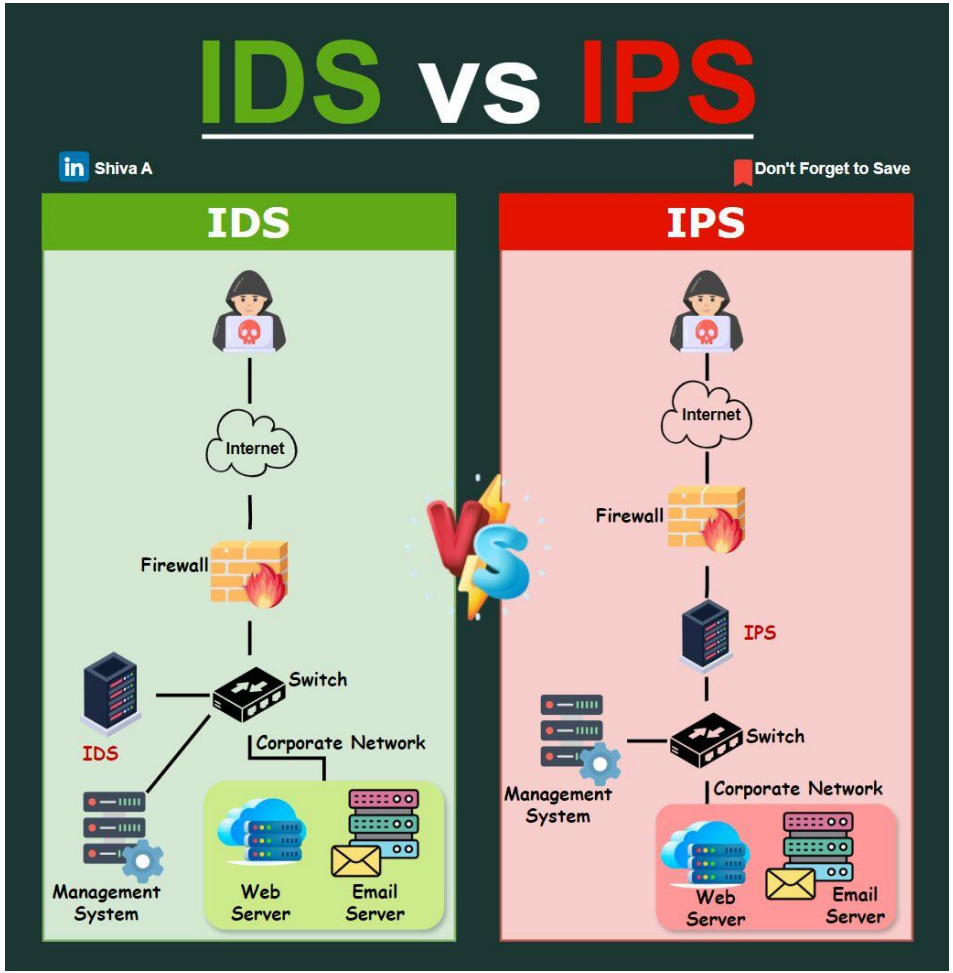
- Anomaly-based methods
  - Creates a baseline that defines normal behavior for the network and clients
  - Deviation from this baseline are detected as suspicious and reportet
  - Advantages
    - Designed to find Zero-Day exploits
    - Can detect insider attacks
  - Disadvantages
    - Higher number of False Positives
    - Needs more performance → delay in traffic possible

Intrusion Detection System – Detection Methods

- Policy-based methods
  - Administrators create a ruleset that defines what traffic is normal / allowed
  - IDS reports traffic that violates the rules
  - Advantages
    - Low False Positives rate
    - Clear defined rules what is normal and what not
  - Disadvantages
    - Administrators need to maintain the rules
    - Can only detect known attacks and no Zero-Day exploits

Intrusion Prevention System

- Basically identical to IDS – detects suspicious traffic
- Differences
  - Does not „only“ report – it actively blocks the traffic and reports
    - E.g.: Sets dynamic filter rules
  - Normally placed inline
- Advantages
  - Quick reaction, no need to wait for a administrator to take care of the issue
- Disadvantages
  - Performance impact
  - In case of false positive: legitimate traffic will be blocked



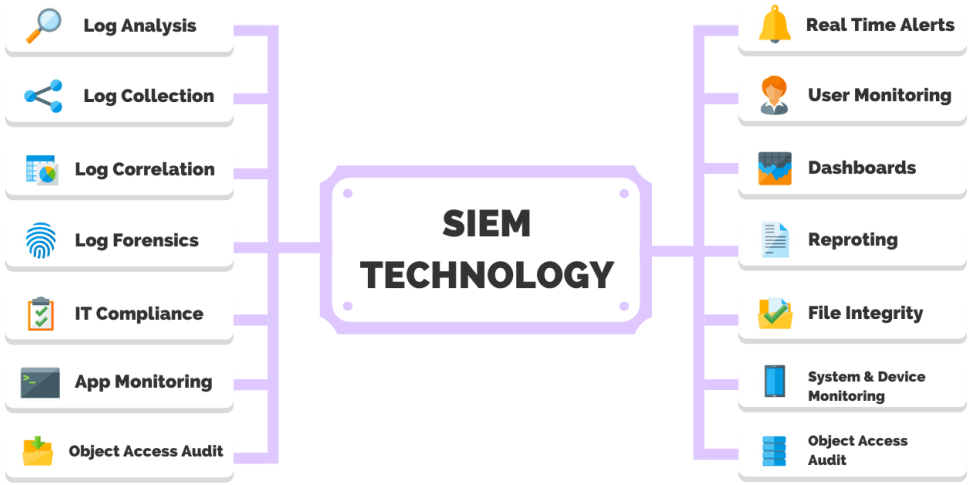
Source: https://www.linkedin.com/posts/ashivak_cybersecurity-ids-ips-activity-7183128338046025728-l8JV

Security Information and Event Management

FH University of Applied Sciences TECHNIKUM WIEN

Security Information and Event Management (SIEM)

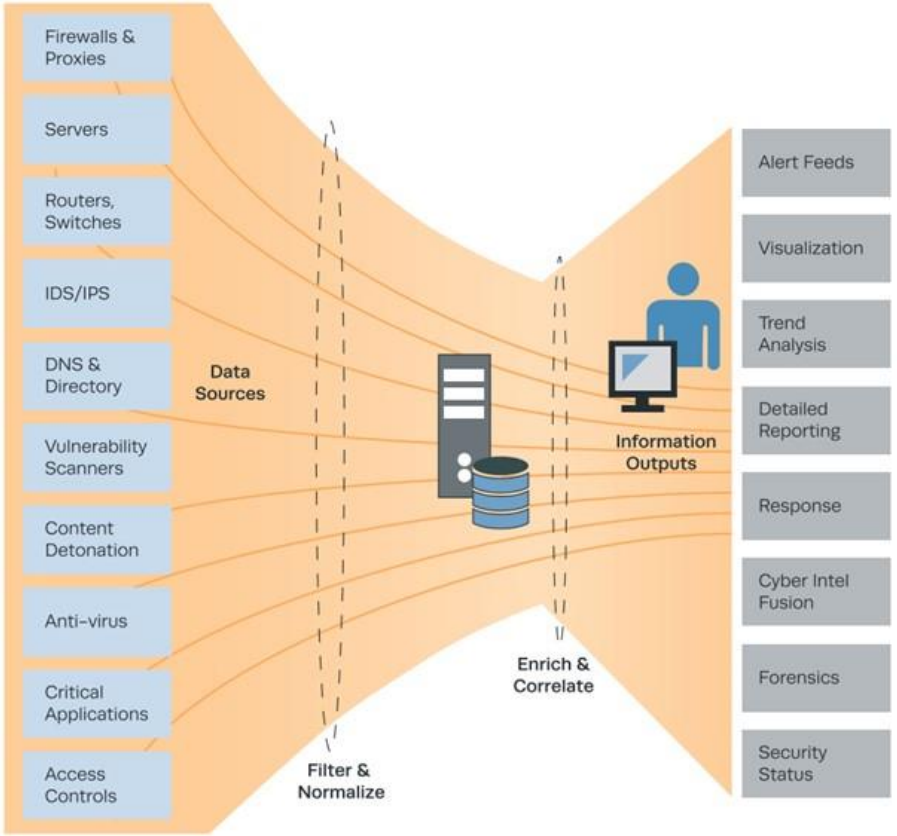
- Functions of a SIEM:
  - Log-Management: Central logging and aggregation of normalized data sets
  - Event correlation: Recognition of logical relationships between data
  - Incident Response: Prompt reaction in the sense of incident management
  - Data evaluation for forensic analysis
  - Real-time monitoring
  - Compliance reporting



Source: https://purplesec.us/learn/siem-solutions/

Security Information and Event Management (SIEM)

- Potential data Sources:
  - Network devices: Firewalls, routers, switches
  - Servers: Web servers, database servers, application servers
  - Endpoints: Workstations, laptops, mobile devices
  - Security tools: Intrusion detection systems (IDS), antivirus software
  - Applications: Business applications, cloud services
  - Operation Systems: System Logs, Application logs



Source: https://www.sycope.com/post/network-flow-monitoring-and-siem-systems

Security Information and Event Management (SIEM)

- Methods to collect data
  - Agent-based collection:
    - Small software agents installed on devices to gather logs
  - Agentless collection:
    - Directly querying devices or systems using protocols like SNMP or WMI
  - Log forwarding:
    - Devices forward logs to the SIEM using syslog or other protocols